

로그 분석 : FYODOR-L Encoded PowerShell Investigation

1. Process Execution Analysis

[Incident Overview] FYODOR-L 호스트에서 총 7건의 Encoded PowerShell 관련 프로세스 생성(Event ID 1)이 확인되었습니다. ProcessGuid와 ParentProcessGuid를 기준으로 상관 분석한 결과, **4개의 핵심 실행 흐름**을 식별했습니다.

> Application & System Execution

Flow 1: Browser 연계 실행

browser_broker.exe



powershell.exe



powershell.exe (-EncodedCommand)

Flow 3: 권한 상승 (SYSTEM)

WmiPrvSE.exe



powershell.exe (-EncodedCommand)

⚠ NT AUTHORITY \ SYSTEM 권한 실행

Registry Persistence Execution

Flow 2 & 4: UAC 우회 및 재실행 구조

fodhelper.exe



powershell.exe



powershell.exe (-EncodedCommand)

Registry Reference

중간 단계의 PowerShell은 특정 레지스트리 값을 읽어 Encoded Payload를 실행하도록 설계되었습니다. (약 1시간 간격 재실행 확인)

- 레지스트리 값
HKCU\Software\Microsoft\Windows Update
Value : Update

로그 분석 : FYODOR-L Encoded PowerShell Investigation

2. PowerShell Script Analysis & Network Correlation

🚫 Anti-Forensics & Defense Evasion

Script Block Logging 분석 결과, 탐지를 회피하기 위한 다음과 같은 보안 기능 무력화 시도가 확인되었습니다.

- **Script Block Logging 비활성화**

PowerShell 내부 객체 `cachedGroupPolicySettings` 조작.

- **AMSI (Anti-Malware Scan Interface) 우회**

`System.Management.Automation.AmsiUtils` 클래스의 `amsiInitFailed` 값을 강제 변경하여 검사 회피.

- **TLS 인증서 검증 비활성화**

HTTPS 통신 시 경고를 무시하도록

`ServerCertificateValidationCallback = {$true}` 설정.

🔗 Network Connection Correlation

총 **3,849**건의 TCP (Port 443) 이벤트 발생.

상관 분석 매칭 구조:

Encoded PowerShell



동일 ProcessGuid



45.77.53.176:443 통신

LLM 기반 멀티 에이전트 분석 환경 설계

보안 도메인 지식의 시스템화: Vertical AI & Agentic Architecture

핵심 설계 사상 및 방법론

Vertical AI

범용 AI가 해결하지 못하는 보안 도메인의 특수성 (로그 포맷, 공격 기법, 대응 정책 등)을 깊게 학습하고 반영한 "보안 특화 AI 시스템"을 지향합니다.

Agentic Architecture

단일 LLM 호출의 한계를 넘어, 독립된 역할을 가진 에이전트들이 협력하여 복잡한 침해사고 분석 태스크를 자율적으로 완수하는 구조를 채택했습니다.

BMAD 방법론

에이전트별 페르소나(CERT, 조사, 요약), 책임 범위, 협업 프로토콜을 체계적으로 설계하여 파이프라인의 신뢰성과 제어 가능성을 목표로 합니다.

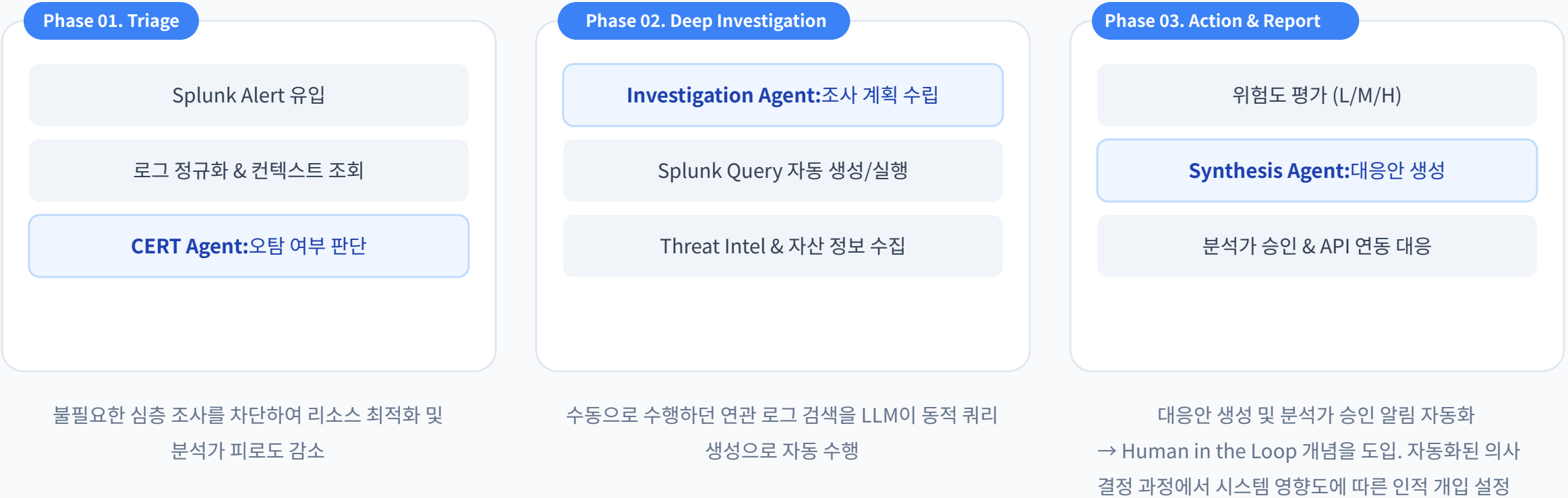
"직접 수행한 침해사고 분석의 경험으로
자동화 시스템(Agentic)의 로직 설계"

수동 분석 과정에서 식별한 Sysmon 로그 상관관계, PowerShell 우회 로직 탐지 패턴 등을 각 에이전트의 프롬프트와 도구 활용 전략에 녹여내어 PoC를 진행했습니다.

자동화 분석 프레임워크 시스템 로직

지능형 Triage부터 대응안 생성까지의 자율 파이프라인 설계

Incident Analysis Pipeline (Agent·BMAD Based)

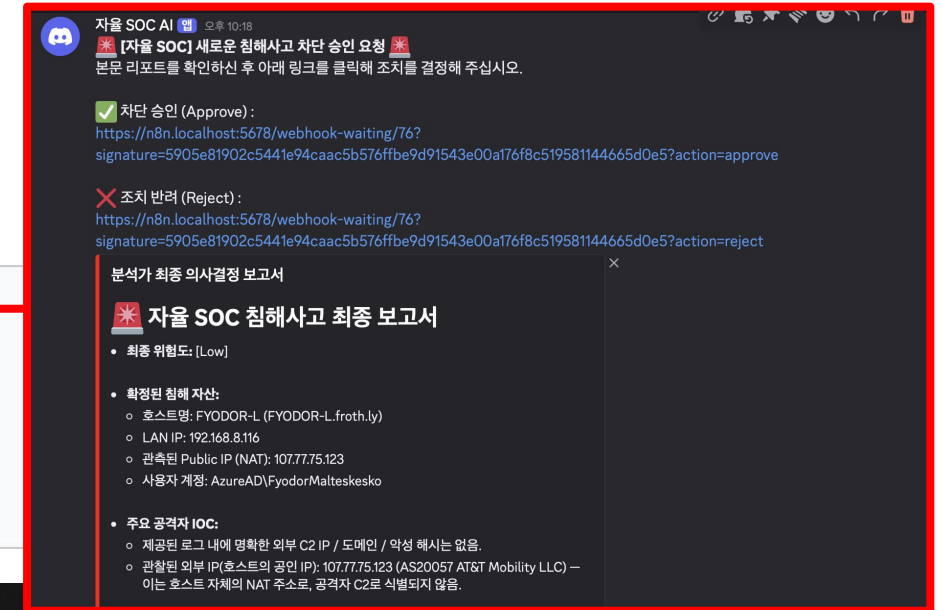
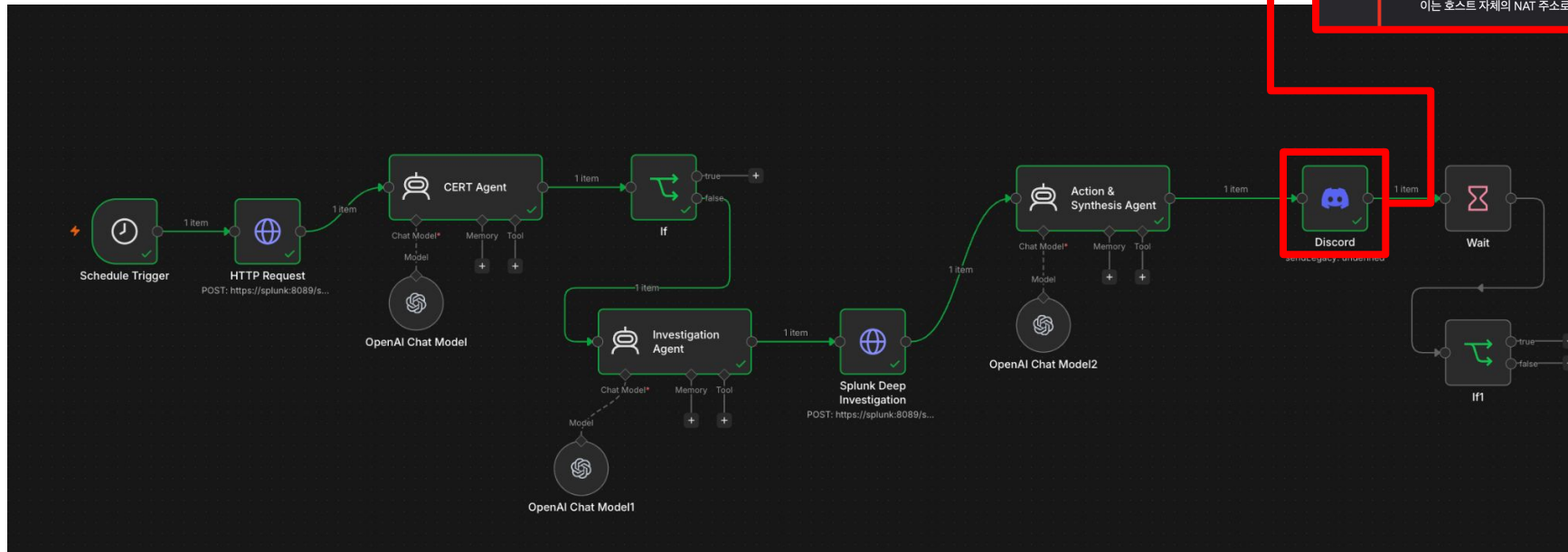


시스템 구현 및 실시간 연동 결과

n8n 기반 멀티 에이전트 구현 및 디스코드 채널 알림 연동

Implementation Stack

- **Orchestration:** n8n Workflow 엔진
- **SIEM:** Splunk REST API 연동
- **LLM:** OpenAI gpt-4o (각 에이전트 페르소나 부여)
- **Notification:** Discord Webhook



1단계: 심층 조사

PHASE 1: TRIAGE & PHASE 2: INVESTIGATION

1단계: Triage Phase

DATA INGESTION

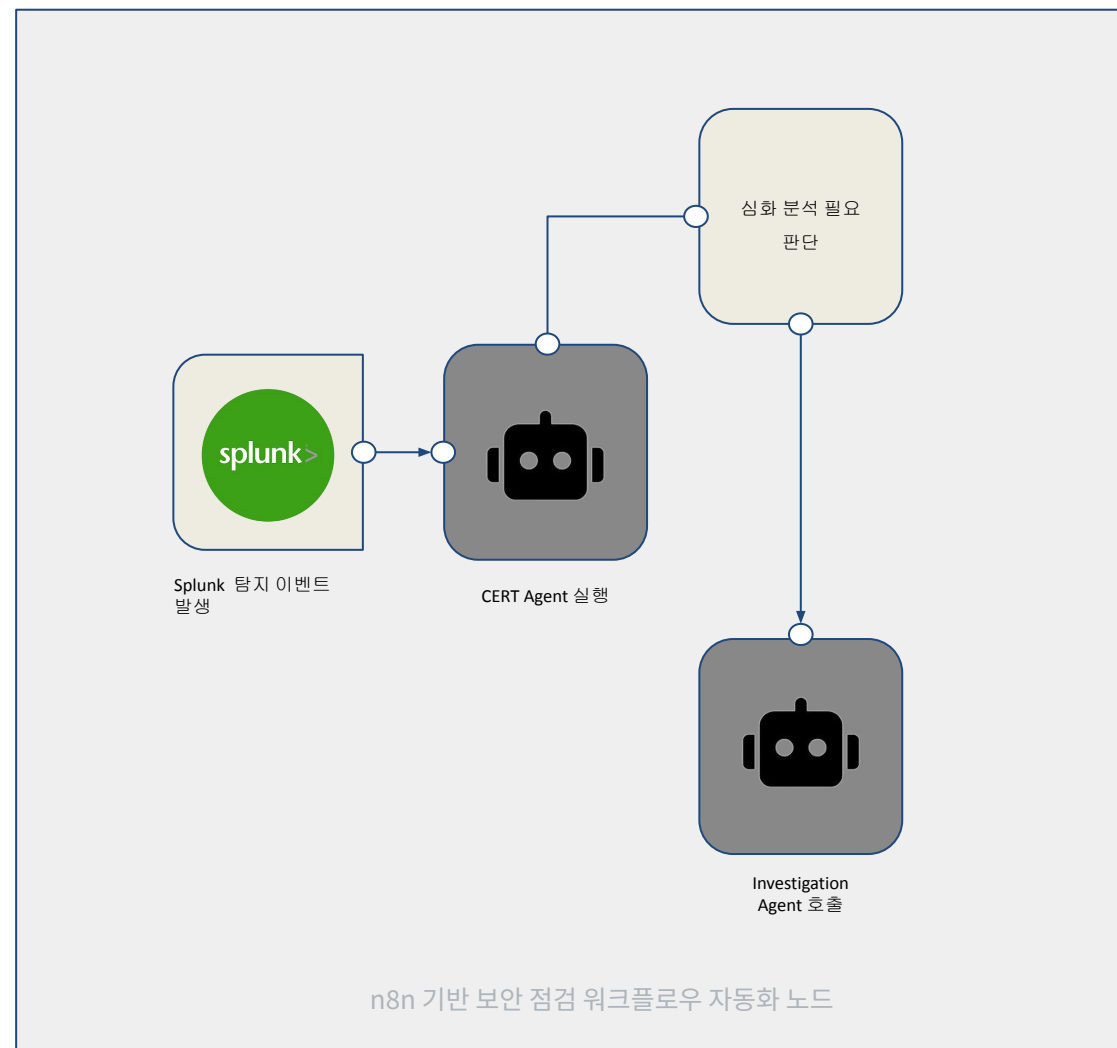
Splunk에서 수집된 엔드포인트 파워셸 스크립트 실행 로그가 n8n 웹훅을 통해 유입

Triage Agent Action

로그 내 난독화(Base64) 페이로드를 자율적으로 디코딩하고 스크립트의 실행 의도를 분석 수행.

OUTPUT

정탐/오탐 식별 후, 정탐일 경우에만 사건을 이관하여 분석 리소스를 최적화.



2단계: 심층 조사

PHASE 1: TRIAGE & PHASE 2: INVESTIGATION

2단계: Investigation Phase

DATA INGESTION

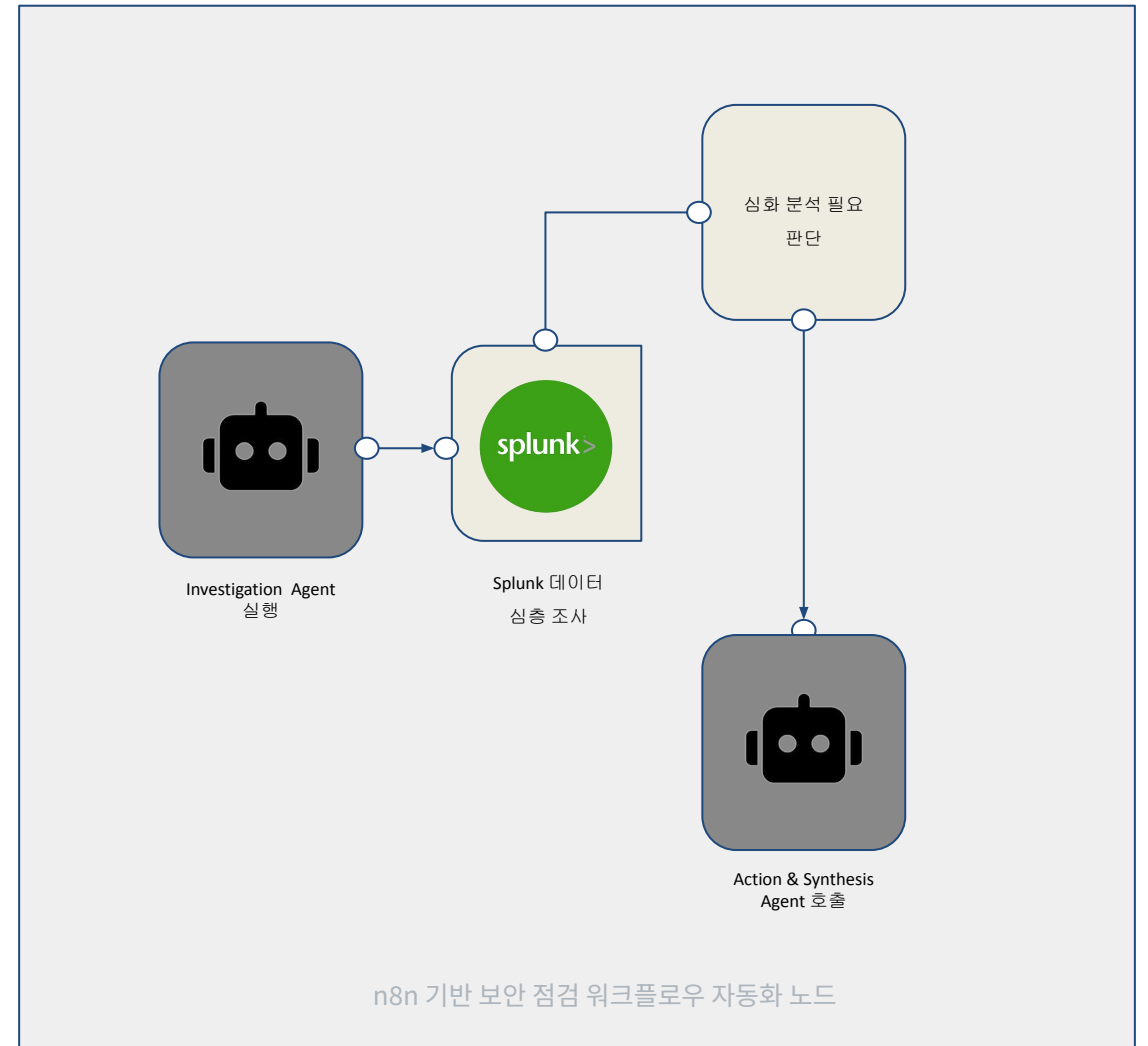
1차 분류를 통과한 정탐 리포트 및 추출된 위협 컨텍스트가 입력.

> Investigation Agent Action

IOC(C2 IP, Hash 등)를 추출하고, Lateral Movement 확인을 위한 최적화된 SPL 쿼리를 직접 작성/질의 수행.

OUTPUT

네트워크 스트림, Sysmon 등 교차 검증용 원시 로그(Raw Data)를 자동으로 확보.



3단계: 종합 평가

PHASE 3: SYNTHESIS & PHASE 4: HUMAN-IN-THE-LOOP

3단계: Synthesis Phase

DATA INGESTION

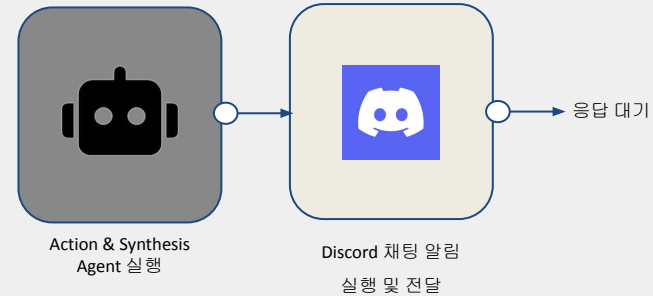
심층 조사를 통해 확보된 다기종 로그(Network, Sysmon, Asset 등) 데이터가 입력.

🔑 Action Agent Action

단편적 로그를 결합하여 전체 공격 타임라인 및 위험도(Risk Level)를 산정하고 대응 플랜을 도출.

OUTPUT

원인, 타임라인, 조치 가이드가 포함된 표준 침해사고 보고서를 자동 생성.



n8n 기반 보안 점검 워크플로우 자동화 노드

4단계: 분석가 통제

PHASE 3: SYNTHESIS & PHASE 4: HUMAN-IN-THE-LOOP

4단계: Human-in-the-Loop

SYSTEM LOGIC

오조치 방지를 위한 최종 Gate. Discord 등 협업 채널을 통해 담당자에게 승인/반려 인터페이스를 제공

⚡ Final Automated Action

담당자 승인 시 n8n이 EDR(호스트 격리) 및 Firewall(IP 차단) API를 호출하여 선제적 방어를 완료.

SAFETY FEATURE

명시적 승인 기반의 대응으로 비즈니스 서비스 가용성을 보장

